VIKAS R

192311353

CSE

ITA1409-ETHICAL HACKING

CO2-AT3

Q1. Footprinting Tools – Conducting Competitive Intelligence (15 Marks)

Introduction

Footprinting is the process of collecting information about an organization from publicly available sources. Passive footprinting gathers information without directly interacting with the target company's servers.

Tools and Their Applications

1. Domain Registration Details – WHOIS

Tool: WHOIS

WHOIS provides domain registration information such as registrar, registration date, expiry date, and nameservers.

Example command:

```
whois example.com
```

Application: The consultant can identify domain ownership information and understand the company's domain infrastructure.

2. Employee Email Addresses – theHarvester

Tool: theHarvester

It collects publicly available email addresses and domain-related information from supported search engines and other public sources.

Example command:

```
theHarvester -d example.com -b duckduckgo
```

Application: It helps identify publicly exposed employee email addresses that could be relevant to organizational security assessments.

3. Technology Stack – BuiltWith

Tool: BuiltWith

BuiltWith identifies publicly detectable website technologies, including content management systems, web frameworks, analytics tools, and hosting technologies.

Application: It helps understand the technologies used by the company's website and identify outdated technologies that may require further defensive review.

4. Publicly Exposed Subdomains – Sublist3r

Tool: Sublist3r

Sublist3r discovers subdomains using supported public search engines and other sources.

Example command:

```
sublist3r -d example.com
```

Application: It helps identify publicly known subdomains such as mail.example.com and portal.example.com.

How These Tools Support Competitive Intelligence

Tool	Information collected	Purpose
WHOIS	Domain registration details	Understand domain ownership and administration
theHarvester	Public email addresses	Map publicly visible employee contact information
BuiltWith	Website technologies	Understand the company's technology stack
Sublist3r	Public subdomains	Identify the public-facing digital footprint

Conclusion

WHOIS, theHarvester, BuiltWith, and Sublist3r help collect publicly available information about a company. These tools support competitive intelligence and passive security assessment without directly interacting with the target servers. All findings should be collected and used lawfully.

Q2. DNS Zone Transfers (15 Marks)

Introduction

A DNS zone transfer (AXFR) transfers DNS records from one DNS server to another. If a DNS server allows unauthorized zone transfers, an external party may retrieve records that reveal information about the organization's infrastructure.

Tool Used

Tool: `dig` command

The `dig` tool queries DNS servers and can be used to check whether a zone transfer is permitted.

Procedure

Step 1: Identify the authoritative DNS server.

```
dig NS example.com
```

This command identifies the nameservers responsible for the domain.

Step 2: Attempt a zone transfer against an authorized test target.

```
dig @ns1.example.com example.com AXFR
```

Replace `ns1.example.com` with the actual authoritative nameserver.

Step 3: Analyze the result.

- If successful: The server returns the DNS records in the zone.
- If refused: The server denies the transfer request.
- If timed out: The result is inconclusive; connectivity or server configuration may be responsible.

Information Revealed by a Successful Transfer

1. Internal hosts: Hostnames and IP addresses may reveal server roles and infrastructure.
2. Mail servers: MX records identify mail servers associated with the domain.
3. Subdomains: Records may reveal subdomains such as `vpn.example.com`, `mail.example.com`, or `dev.example.com`.
4. Network structure: DNS names and records may reveal the organization's systems and services.

How Attackers Could Use This Information

- Perform further reconnaissance on discovered hosts.
- Identify exposed services and possible entry points.
- Research known vulnerabilities associated with identified technologies.
- Prepare targeted phishing campaigns using discovered organizational details.

A successful transfer exposes information; it does not automatically provide access to the discovered systems.

Countermeasures

- Restrict AXFR requests to authorized secondary DNS servers.
- Configure access control lists (ACLs).
- Use TSIG authentication for zone transfers.
- Separate internal and external DNS records where appropriate.
- Monitor DNS logs for suspicious transfer attempts.
- Conduct regular DNS configuration audits.

Conclusion

The `dig` command helps verify whether a DNS zone transfer is permitted. Unauthorized AXFR access may reveal hostnames, mail servers, and subdomains. Proper access restrictions, authentication, and monitoring help secure DNS infrastructure.

Q3. Social Engineering Attacks and Countermeasures (20 Marks)

Introduction

Social engineering is an attack technique that manipulates people into revealing confidential information or performing unsafe actions. In this scenario, employees receive an email pretending to be from the IT department and requesting login credentials through an urgent security-update link.

Type of Attack: Phishing

This is a phishing attack because the attacker impersonates a trusted department to trick employees into revealing their login credentials.

The email uses two common techniques:

- Impersonation: Pretending to be the organization's IT department.
- Urgency: Claiming that an immediate security update is required to pressure employees into acting quickly.

How the Attack Works

1. The attacker sends a fraudulent email to employees.
2. The email claims that employees must verify their credentials.
3. Employees click the provided link.
4. The link opens a fake login page.
5. Employees enter their usernames and passwords.
6. The attacker captures the credentials and may attempt unauthorized account access.

Countermeasures Employees Should Follow

1. Verify the sender

Check the complete email address and domain instead of trusting the display name.

2. Avoid clicking suspicious links

Hover over links to inspect their destinations, and use a trusted bookmark or manually enter the organization's official website.

3. Never disclose passwords through email links

Employees should not enter credentials on unexpected pages requesting verification.

4. Confirm urgent requests independently

Contact the IT department through an official phone number or internal communication channel.

5. Check for suspicious signs

Look for unexpected requests, unusual wording, mismatched domains, and suspicious attachments.

6. Report the email

Use the organization's phishing-reporting process and notify the IT security team.

7. Do not download unexpected attachments

Suspicious attachments may contain malware that can compromise the employee's computer.

Organizational Security Measures

Security measure	Purpose
Employee awareness training	Helps employees recognize phishing attempts
Email spam filtering	Blocks suspicious messages
SPF, DKIM, and DMARC	Helps protect against email-domain spoofing
Multi-factor authentication (MFA)	Adds protection if a password is stolen
Endpoint protection	Detects and blocks malicious files
Phishing simulations	Measures awareness and improves employee response
Incident response policy	Ensures suspicious emails and compromised accounts are handled quickly

How These Measures Prevent Credential Theft

- Sender verification helps detect impersonation.
- Link inspection reduces the chance of visiting fraudulent login pages.
- Independent verification prevents attackers from exploiting urgency.
- MFA makes stolen passwords less useful to attackers.
- Email filtering reduces the number of phishing messages reaching employees.
- Reporting enables the security team to block malicious links and warn other users.

Conclusion

The scenario demonstrates a phishing attack that uses impersonation and urgency to steal credentials. Employee awareness, independent verification, secure email configurations, MFA, and prompt reporting can significantly reduce the risk of credential theft and unauthorized access.